Assignment 4 — Security, Resilience, and Intrusion Tolerance

Synthetic Kazakhstan University Research Server Incident

Talgatov Aibyn · Student ID 255308 · CSE-2505M · Instructor: Serek Azamat

Astana IT University | Fault Tolerance | Academic Year 2026–2027

Context note: All operational data in this assignment are synthetic educational data. They are designed to represent a realistic Kazakhstan/Astana university context and do not describe actual AITU infrastructure, incidents, or internal systems.

Key terms in plain words

The report uses a number of security terms. Each one is explained here in plain words, so the rest of the report can be read without a security background.

Term	Meaning in plain words
Anomaly score	A number from 0 to 1 that an AI model gives a signal to show how unusual it is compared with normal. Here a score of 0.75 or more counts as an anomaly.
Assume breach	A way to test a design: pretend the attacker is already inside and check whether detection and recovery still limit the damage.
Attack stage	One step of an attack, such as getting in, doing damage or covering tracks. The assignment gives eight stages to choose from.
Bastion (jump host)	The single, well-protected server through which administrators reach the internal servers. MFA, lockout and logging sit on it.
Brute force	Guessing a password by trying many options until one works.
C2 (command and control)	The connection an attacker uses to send orders to a computer they have taken over.
Canary file	A decoy file that nobody should ever touch. Any change to it is a strong sign of an attack.
Clean restore point	The last backup made before the attack, so it contains no damage. Here 09:06, or 09:03 as a fallback.
Clean room (recovery environment)	A separate network with no internet access where restored data is checked before it goes back into use.
Critical path	The longest chain of steps that must happen one after another. It sets the total recovery time (20 minutes here).
Default-deny	A rule style where everything that is not explicitly allowed is blocked.
Defense in depth	Several independent layers of protection, so that one failing layer does not mean the attacker wins.
Detective control	A control that notices an attack while it happens and raises an alert.
Double extortion	Encrypting the victim's data and also stealing it, then threatening to publish it.
EDR (endpoint detection and response)	Software on a computer that watches what programs do and can stop suspicious behaviour.
Egress filtering	Rules that decide which outside addresses a server may connect to. Here only an approved list is allowed.
Entropy	A measure of how random data looks. Encrypted files look almost completely random, which tells encryption apart from normal editing.
Estimated recovery time	How long the recovery plan is expected to take. It is an estimate, not a measured result.
Exfiltration	Copying stolen data out of the organisation's network.
Failover	Moving a service from a failed server to a spare one.
FIM (file integrity monitoring)	Watching files and recording when they are created, changed or deleted.

Term	Meaning in plain words
Firewall	A device that checks network traffic and lets through only what its rules allow. Here OPNsense.
Golden image	A prepared and checked copy of a server's system, used to build a clean server quickly.
Hash (SHA-256)	A short fingerprint calculated from a file. If even one bit of the file changes, the fingerprint changes.
Hypervisor	The software that runs virtual machines. It can pause a machine, move it to another network and take snapshots of it.
IDS (intrusion detection system)	A system that watches network traffic or a single computer for signs of attack. It raises alerts but does not block.
Immutable backup	A backup copy that cannot be changed or deleted until its keep-until date, not even by an administrator.
Impact	How much damage a threat would cause, scored from 1 to 5.
Just-in-time access	Administrator rights given for a short, approved time window and then taken away automatically.
KZ-CERT	Kazakhstan's national computer emergency response team, to which cyber incidents are reported.
Lateral movement	Moving from one captured computer to other computers inside the same network.
Law No. 94-V	The Kazakhstan law on personal data. Its Article 12 requires databases with personal data to be stored inside Kazakhstan.
Least privilege	Giving each account only the rights it really needs to do its job.
Likelihood	How probable a threat is, scored from 1 to 5. Here it is based on what the log shows.
Live replication	Copying every change to a spare server as it happens. Not used here, because it would also copy the encrypted files.
Lockout	An automatic block after too many failed logins. Here: 10 failures within 5 minutes blocks the source address.
MFA (multi-factor authentication)	A login that needs something you know (a password) and something you have (a code from a phone app or a hardware key). A guessed password alone is not enough.
MITRE ATT&CK	A public catalogue of real attacker behaviour. A tactic (ID TA…) is the goal of a step; a technique (ID T…) is how the attacker reaches it.
Object Lock	A storage setting that forbids deleting or changing a saved copy before a set date. In compliance mode nobody can lift it.
Offline copy (air gap)	A backup copy that is disconnected from the network most of the time, so it cannot be reached remotely.
PAM (privileged access management)	Control over who gets administrator rights, when and for how long, with approval and a record of use.
Persistence	Actions that let an attacker keep access after a restart or a password change.
Preventive control	A control that stops an attack from succeeding in the first place.
Privilege escalation	Gaining more rights than the account started with, for example administrator rights.
Pull-only backup	The backup store fetches the copies itself. The server has no access to the store, so a captured server cannot delete its backups.
Quarantine network	A separate network zone with no access to anything else, where an infected machine is moved.
Ransomware	Malicious software that encrypts data and demands payment for the key.
Reconnaissance	Gathering information about a target before attacking it.
Recovery control	A control that brings systems and data back after damage.
Replication lag	The delay between a change and its arrival in the backup store (1 minute here).
Risk score	Likelihood × Impact. 1–4 is Low, 5–9 Medium, 10–16 High and 17–25 Critical.
RPO (recovery point objective)	The target for how much data, measured in minutes of work, may be lost. Here at most 5 minutes.
RTO (recovery time objective)	The target for how long the service may be down. Here at most 30 minutes.
Segmentation	Dividing the network into separate zones with rules between them, so breaking into one zone does not open the others.
SIEM (security information and event management)	A system that collects logs from everywhere, links related events and raises alerts. Here Wazuh.
Snapshot	An instant picture of a disk at one moment, which can be restored later.
Spare server (warm standby)	A second server that is already running and waiting to take over. Here RS-02.

Term	Meaning in plain words
SSH	The standard way to log in to a server remotely and type commands. The attacker guessed an SSH password.
Threshold	The cut-off value at or above which a score is treated as an anomaly (0.75 here).
Vault	The separate, protected store that holds the backups.
Virtual machine (VM)	A computer simulated in software on a physical host. RS-01 and RS-02 are virtual machines.
VLAN	A separate logical network on shared network hardware. VLANs are how the zones are built.
WORM (write once, read many)	Storage that can be written once and afterwards only read. Evidence is kept there so it cannot be altered.
Worst-case data loss	The most work, in minutes, that the backup design can lose: here 3 + 1 = 4 minutes.

Incident dataset (synthetic)

Time	Event	Source	Severity
09:01	15 failed logins	10.20.4.15	Medium
09:03	21 failed logins	10.20.4.15	High
09:04	Successful login	10.20.4.15	High
09:07	320 files modified	10.20.4.15	Critical
09:08	CPU usage increased to 95%	Research-Server-01	High
09:10	1,200 files encrypted	Research-Server-01	Critical
09:12	Backup deletion attempt	Research-Server-01	Critical
09:13	Outbound connection to unknown IP	Research-Server-01	High
09:15	Database access spike	Research-Server-01	High
09:18	Antivirus disabled	Research-Server-01	Critical

Part A — Incident Analysis

In plain words: The log shows one attacker who guessed a password, logged in, encrypted the research files, tried to delete the backups, opened a connection to the outside and switched off the antivirus, all within 17 minutes. The table names the attack stage of each event, the evidence for that choice and how serious the event is.

Classify each event as reconnaissance, credential attack, privilege compromise, lateral movement, data destruction, persistence, exfiltration, or recovery attack.

Time	Event	Attack stage	Evidence	Risk
09:01	15 failed logins	reconnaissance	First contact from 10.20.4.15: 15 failed logins in the first logged burst (Medium severity). Consistent with probing which usernames exist and whether lockout is enforced. (ATT&CK: T1589 Gather Victim Identity Information (tactic: Reconnaissance)) Alternative reading: Start of the credential attack (T1110).	Medium
09:03	21 failed logins	credential attack	21 more failed logins from the same source 10.20.4.15; 36 cumulative failures logged between 09:01 and 09:03. (ATT&CK: T1110.001 Password Guessing (tactic: Credential Access))	High
09:04	Successful login	privilege compromise	Successful login from 10.20.4.15 immediately after 36 failed attempts (first failure logged 09:01): a guessed password became a valid session. (ATT&CK: T1078 Valid Accounts (tactic: Initial Access))	Critical
09:07	320 files modified	data destruction	320 files modified by the attacker session (source 10.20.4.15), 3 min after the successful login. (ATT&CK: T1486 Data Encrypted for Impact (tactic: Impact))	Critical

Time	Event	Attack stage	Evidence	Risk
09:08	CPU usage increased to 95%	data destruction	CPU at 95% on Research-Server-01, 1 min after the 320 file modifications and 2 min before 1,200 files are reported encrypted, so consistent with the encryption workload. (ATT&CK: T1486 Data Encrypted for Impact (tactic: Impact)) Alternative reading: 95% CPU alone is not specific on a research server (see Part E); resource hijacking (T1496) is less likely given the timing.	High
09:10	1,200 files encrypted	data destruction	1,200 files encrypted on Research-Server-01: direct loss of research data. (ATT&CK: T1486 Data Encrypted for Impact (tactic: Impact))	Critical
09:12	Backup deletion attempt	recovery attack	Backup deletion attempt on Research-Server-01, 2 min after encryption: an attack on the ability to recover. (ATT&CK: T1490 Inhibit System Recovery (tactic: Impact))	Critical
09:13	Outbound connection to unknown IP	exfiltration	Outbound connection from Research-Server-01 to an unknown IP. No transfer volume is logged, so exfiltration is assessed, not confirmed. (ATT&CK: T1041 Exfiltration Over C2 Channel (tactic: Exfiltration)) Alternative reading: A command-and-control channel only; double extortion is a hypothesis.	High
09:15	Database access spike	lateral movement	Database access spike from Research-Server-01: the compromised server is used as a pivot into the research database. Stated assumption: the database runs on a separate host. The queries may feed the outbound channel opened at 09:13. (ATT&CK: TA0008 Lateral Movement (assumed T1021 Remote Services, RS-01 → DB) + T1213 Data from Information Repositories (tactic: Collection)) Alternative reading: Exfiltration (collection).	High
09:18	Antivirus disabled	persistence	Antivirus disabled on Research-Server-01 at 09:18, 8 min after 1,200 files were encrypted. The dataset shows no AV alert during 09:07–09:10, so AV did not stop the encryption. Disabling it protects the attacker's continued access and hampers forensics. (ATT&CK: T1562.001 Impair Defenses: Disable or Modify Tools (tactic: Defense Evasion)) Alternative reading: Defense evasion; the spec vocabulary has no such stage, so it is classed as persistence.	Critical

Attack metrics: 36 failed logins in total; compromise after 3 min; encryption 6 min after compromise; 17 min from first contact to disabled antivirus. Risk is the assessed risk: it equals the dataset severity except 09:04, raised to Critical.

Part B — Risk Matrix

In plain words: Each threat gets two scores from 1 to 5: how likely it is and how much damage it would do. Multiplying them gives the risk score. Ransomware scores highest (25) because it happened and destroyed data. Backup destruction and a stolen password follow with 20 each.

Risk = Likelihood × Impact. Use 1–4 Low, 5–9 Medium, 10–16 High, 17–25 Critical.

Threat	Likelihood	Impact	Risk Score	Priority
Credential compromise	5	4	20	Critical (#3)
Ransomware	5	5	25	Critical (#1)
Backup destruction	4	5	20	Critical (#2)
Data exfiltration	4	4	16	High (#4)

Threat	Likelihood	Impact	Risk Score	Priority
Privilege escalation	4	4	16	High (#5)

Scoring rules. Likelihood 5 = observed and succeeded in this incident; 4 = attempted or indirectly evidenced, with the outcome not logged. Impact 5 = loss of research data or of the ability to recover; 4 = serious but bounded (access or confidentiality). Ranking: score, then impact, then template order.

Threat	Likelihood rationale	Impact rationale	Sensitivity (L-1 / L / L+1)
Credential compromise	L5 (observed and succeeded): the 09:04 login succeeded after 36 guesses against password-only access.	I4: it grants entry to the research server but is not damage by itself.	High / Critical / Critical
Ransomware	L5 (observed and succeeded): 1,200 files were encrypted by 09:10.	I5: loss of research data and of the server's availability.	Critical / Critical / Critical
Backup destruction	L4 (attempted, outcome not logged): a deletion attempt at 09:12 against mutable backups, by an attacker who already held the rights it needs.	I5: it removes recoverability, turning a recoverable incident into permanent loss.	High / Critical / Critical
Data exfiltration	L4 (indirectly evidenced): an outbound connection to an unknown IP (09:13) and a database spike within 2 min (09:15), with no transfer volume logged.	I4: confidentiality loss of research and personal data with legal exposure, but no data destroyed.	High / High / Critical
Privilege escalation	L4 (indirectly evidenced): disabling antivirus and deleting backups both require administrative rights.	I4: an enabler of the other threats rather than damage by itself.	High / High / Critical

Implementation order. What to fix first is a separate choice from the risk rank. MFA comes first because it removes the cause (a guessed password was enough to get in); immutable backup comes second because it still saves the data when every other layer fails.

Part C — Resilient Security Architecture

In plain words: The design surrounds the research server with several independent layers. Some layers stop the attack (preventive), some notice it (detective) and some bring the system back (recovery). Every threat is covered by all three kinds, so the attacker has to defeat more than one layer to win.

Design a synthetic architecture containing MFA, network segmentation, immutable backup, monitoring, intrusion detection, secure failover, and a recovery environment.

Threat	Preventive control	Detection control	Recovery control
Credential attack	MFA on the bastion and VPN; per-source-IP lockout at 10 failures / 5 min (per IP, not per account, so attackers cannot lock researchers out); SSH unreachable from the user VLAN	SIEM alert at ≥10 failures / 5 min per source; "success after failures" correlation	Respond: block the source, revoke sessions. Recover: rotate the password, re-enrol MFA, review account activity

Threat	Preventive control	Detection control	Recovery control
Ransomware	Segmentation; least-privilege write access to research shares; noexec on /tmp, /dev/shm and user-writable mounts plus application allow-listing (fapolicyd)	Canary-file write (immediate); FIM rate ≥100 changes/min AND extension/entropy change; CPU >90% and AI score used only as correlating signals	Respond: the hypervisor pauses RS-01 and moves it into the quarantine VLAN. Recover: restore data from the verified clean point onto RS-02, verify it in the clean room, then promote RS-02
Backup deletion	Pull-only vault, so production holds no vault credentials; zfs hold on vault snapshots; Object Lock compliance mode on the restic tier; just-in-time admin	Alert on any delete or retention-change API call, or a failed vault login	Recover: restore from the vault (tier 1, then the Object Lock tier); the offline Almaty copy is the last resort
Data exfiltration	Egress default-deny allow-list proxy; least-privilege database roles	Suricata alert on a non-allow-listed destination and on volume anomalies; database query-rate anomaly	Respond: block the destination, revoke database credentials. Recover: scope the leaked records, report to KZ-CERT, and notify the authorised personal-data body and data subjects where Law No. 94-V and university policy require it
Privilege escalation	Just-in-time admin, no standing root, agent tamper protection	Alert on AV/EDR stop, a new admin account, or sudo outside the just-in-time window	Recover: rebuild the host from a golden image in the clean room; rotate all privileged credentials

Component inventory and the defence of each role:

Required component	Implementation	Zone	Role	Why this role
MFA	Multi-factor authentication: privacyIDEA TOTP/push via its PAM module on the SSH bastion and its FreeRADIUS plugin on the VPN; administrators additionally use FIDO2 OpenSSH keys (ed25519-sk); per-source-IP lockout at 10 failures / 5 min	Access zone	preventive	Preventive: stops a guessed password from becoming a session; it would have blocked the 09:04 login.
Network segmentation	Network segmentation: OPNsense firewall, VLANs, default-deny inter-zone rules, egress allow-list proxy, quarantine VLAN	All zone boundaries	preventive	Preventive by design: 10.20.4.15 reaches RS-01 only through the bastion and unknown egress (09:13) is denied. Its quarantine VLAN is reused for containment in recovery step 2.
Supporting (not one of the 7 required)	Privileged access management: Just-in-time sudo, separate admin accounts, no standing root, agent tamper protection	Access zone	preventive	Preventive: backup deletion (09:12) and disabling antivirus (09:18) need a just-in-time approval the attacker does not have.
Monitoring	Monitoring / SIEM: Wazuh SIEM + Prometheus/Grafana, correlation rules, active response	Security zone	detective	Detective: raises the 09:01 and 09:07 alerts. Its active response only orchestrates; the hypervisor, firewall and identity provider carry out the containment.

Required component	Implementation	Zone	Role	Why this role
Intrusion detection	Intrusion detection: Suricata NIDS, Wazuh HIDS/FIM with canary files and an extension/entropy check, AI anomaly scorer	Security zone	detective	Detective: detects the encryption (09:07) and the unknown outbound connection (09:13).
Immutable backup	Immutable backup: Tier 1 (fast restore): ZFS snapshots every 3 min on RS-01, pulled by the vault (zfs send -i | zfs receive, initiated from the vault) into its own pool and held with zfs hold; PostgreSQL WAL pulled continuously by pg_receivewal on the vault plus a nightly base backup. Tier 2 (WORM): restic copies every 15 min into a MinIO bucket with S3 Object Lock in compliance mode (30 days). Production holds no vault credentials	Backup vault (pull-only)	recovery	Recovery against ransomware: it does not stop encryption, but keeps clean restore points out of the attacker's reach. Tier 1 (worst-case loss 4 min) is protected by credential separation and zfs hold; tier 2 is write-once even for a vault administrator.
Secure failover	Secure failover: Research-Server-02: warm VM cloned from a golden image, holds no data and waits in the isolated recovery VLAN, out of reach of an attacker in the research VLAN; promoted after verification by re-tagging its vNIC into the research VLAN and switching the service VIP/DNS	Recovery zone (isolated VLAN; moved into the research VLAN on promotion)	recovery	Recovery: restores service on clean infrastructure within the RTO and never receives live-replicated (encrypted) data.
Recovery environment	Recovery environment: Isolated clean-room VLAN without internet access: restore, scan, verify	Recovery zone (isolated VLAN)	recovery	Recovery: restored data is verified in isolation before it returns to production.
Supporting (not one of the 7 required)	Virtualisation host (hypervisor): VM cluster running RS-01 and RS-02; its API lets Wazuh active response pause a VM, re-tag its vNIC into the quarantine VLAN and take memory + disk snapshots for evidence	Research zone (platform)	recovery	Response point, listed with recovery because the template has no respond column: containment and evidence capture happen here, since VLAN membership is set on the vNIC, not on the firewall.
Additional (Part E Q4, section 6)	Offline copy at a second Kazakhstan site: Logically air-gapped copy in Almaty (~970 km from Astana): transfer window opened daily from the Almaty side only, monthly rotation to disconnected media, separate admin domain, monthly restore drill; data-loss tier 24 h	Second site (Almaty)	recovery	Recovery: last resort that survives compromise of the vault's admin plane or loss of the Astana site.

Whether a control counts as preventive, detective or recovery depends on the threat. Object Lock prevents backup deletion, while the backup as a whole is a recovery control against ransomware. The SIEM detects and gives orders; the hypervisor, the firewall and the login server carry them out. The template has no separate “respond” column, so these actions appear in the recovery column marked “Respond:”.

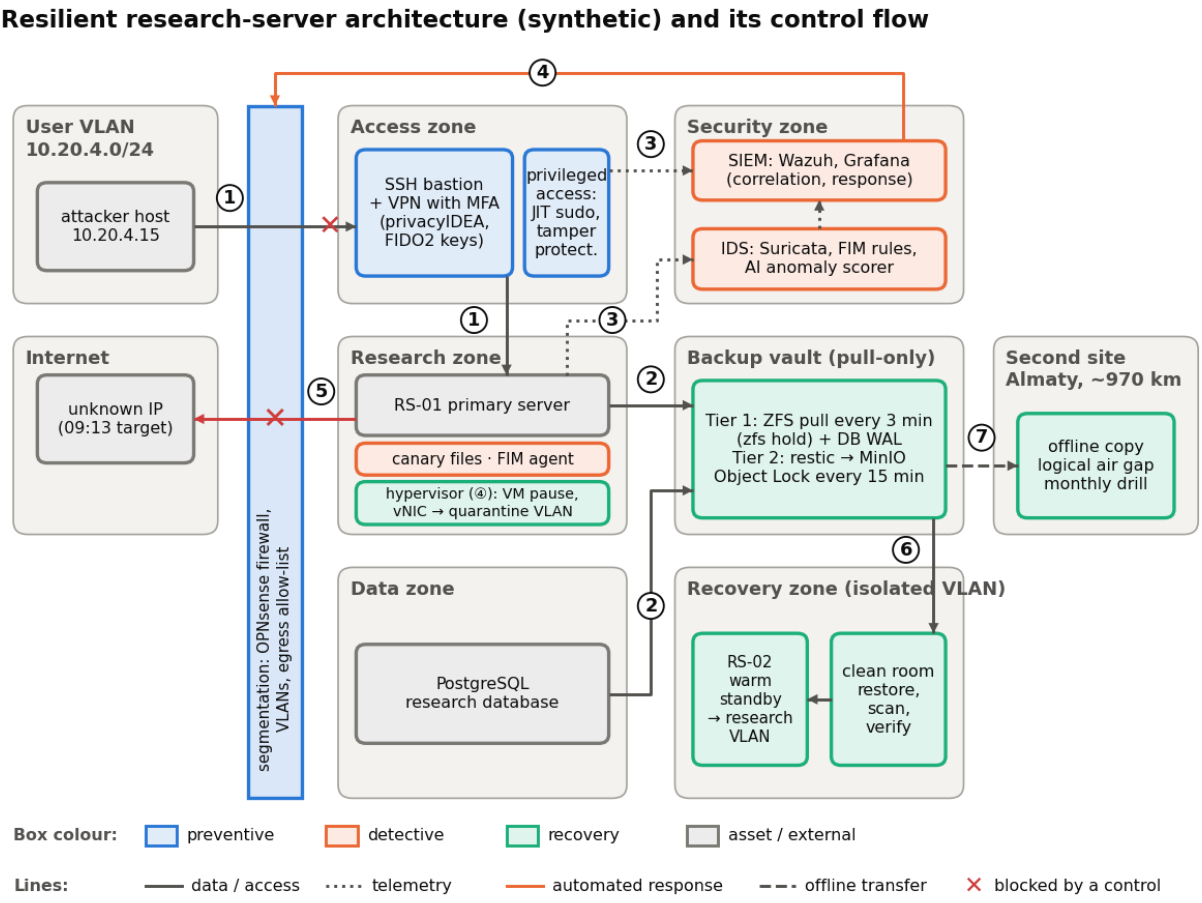


Figure 1. Resilient architecture and its numbered control flow (1)–(7).

How to read Figure 1

Figure 1 reads from left to right: the networks outside the perimeter, the segmentation boundary (blue bar), the production zones, the protection and recovery zones, and the second site. Box colour shows the control role: blue = preventive, orange = detective, green = recovery, grey = protected asset or external system. Lines: solid = access or data path (the arrowhead shows the direction of data), dotted = telemetry, orange = automated response, dashed = scheduled offline transfer, red ✕ = path blocked by a control. Numbers (1)–(7) mark the control flow.

Zones, from left to right:

- **User VLAN 10.20.4.0/24:** the campus network the attack came from (attacker host 10.20.4.15); it has no direct route to the research servers.
- **Internet:** the destination of the 09:13 outbound connection, reachable only through the egress allow-list.
- **Segmentation boundary:** OPNsense firewall and VLAN switching: default-deny between zones, egress allow-list, quarantine VLAN. Every arrow crossing it is an explicitly allowed or blocked path.
- **Access zone:** the SSH bastion and VPN with MFA, the only way into the research zone, and privileged access management (just-in-time sudo, tamper protection).
- **Research zone:** RS-01 with its canary files and FIM agent, running as a VM on the hypervisor that performs containment.
- **Data zone:** the PostgreSQL research database, whose WAL the vault pulls continuously.

- **Security zone:** the intrusion detection system (network monitoring, file monitoring, canary files, AI anomaly scoring) feeding the SIEM, which links related alerts and starts the automatic response.
- **Backup vault:** it fetches the copies itself. Tier 1 keeps snapshots of RS-01 every 3 min that cannot be deleted while held; tier 2 keeps locked copies every 15 min. The production servers have no password for the vault.
- **Recovery zone:** a separate network without internet: the clean room where restored data is scanned and checked, and the RS-02 spare server, which joins the research network only after the check.
- **Second site (Almaty):** the offline copy, refreshed in a daily transfer window opened from the Almaty side.

Control flow:

- **(1) Access:** attacker → firewall → bastion. Remote login (SSH) is possible only to the bastion, where MFA rejects the guessed password (red ✕, the 09:04 login). Authorised users continue from the bastion to RS-01.
- **(2) Backup:** RS-01 and the database → vault. The vault fetches the copies itself (snapshots every 3 min, the database change log continuously), so RS-01 holds no password the 09:12 deletion attempt could use.
- **(3) Telemetry:** bastion → SIEM, and RS-01 (file monitoring, canary files) → IDS → SIEM. The failed logins raise the 09:01 alert and the mass file change raises the 09:07 alert.
- **(4) Response:** SIEM → enforcement points. The SIEM asks the hypervisor to pause RS-01 and move it into the quarantine network, and the firewall blocks its traffic (isolated by 09:09).
- **(5) Egress control:** RS-01 → Internet. The connection to the unknown address is blocked at the firewall (red ✕, the 09:13 channel fails).
- **(6) Restore:** vault → clean room → RS-02. Data from the clean restore point is restored and checked in the isolated clean room, then RS-02 joins the research network (estimated recovery time 24 min, 20 min on the critical path).
- **(7) Last-resort copy:** vault → Almaty. Once a day, a transfer window copies the vault to the offline site.

Part D — Recovery Plan

In plain words: If an attack still gets through, the plan brings the service back in seven steps. The estimated recovery time is 20 minutes when steps that can overlap do overlap (24 minutes one after another), within the 30-minute target. Backups are taken every 3 minutes and arrive 1 minute later, so the worst-case data loss is 4 minutes of work, within the 5-minute target.

Requirements: RPO ≤ 5 minutes; RTO ≤ 30 minutes.

Step	Action	Responsible component	Target time
1	Detect incident	ids + monitoring (canary / FIM + entropy rule, SIEM correlation, AI score)	1 min (by T+1)
2	Isolate affected system	hypervisor (VM pause, vNIC into the quarantine VLAN) + segmentation (OPNsense deny rule) + privacyIDEA/IdP (account lock), triggered by Wazuh active response	1 min (by T+2)
3	Preserve evidence	hypervisor (VM memory + disk snapshot) + monitoring (SIEM log export, SHA-256, WORM bucket)	4 min (by T+6, parallel with step 4)
4	Activate backup	immutable_backup (choose the clean point, clone it read-only from the vault ZFS pool into the clean room)	3 min (by T+5, parallel with step 3)
5	Restore services	failover (RS-02 warm VM from a golden image; data copied from the clean point; PostgreSQL PITR)	8 min (by T+13)
6	Verify integrity	recovery_env (hash manifest, YARA/AV scan, persistence check, DB consistency, canaries intact)	5 min (by T+18)
7	Return to production	failover + hypervisor (RS-02 vNIC into the research VLAN, VIP/DNS switch, rotated credentials)	2 min (by T+20)

RTO. Estimated recovery time 24 min if every step waits for the previous one, 20 min on the critical path (steps 1→2→4→5→6→7; evidence is collected at the same time as steps 4–5, because restoring onto RS-02 does not touch RS-01). Both are within the 30-minute target, with 6 min to spare.

RPO. Snapshots every 3 min (starting at 09:00) + 1 min delay before they reach the vault = 4 min worst-case data loss, within the 5-minute target. The restore point is chosen in step 4, before restoring: 09:06 (the last snapshot before the first harmful change at 09:07) if it shows no unexpected changes compared with 09:03, otherwise 09:03 (before the attacker logged in at 09:04). That means 1 or 4 min of lost work. With the fallback point, the loss grows with how long the attacker was inside.

- **Step 1.** Canary write or FIM rate + entropy rule fires on the 09:07 mass modification; Wazuh correlates it with the 09:01 brute-force alert and the AI score.
- **Step 2.** Automated: the hypervisor pauses RS-01 (memory preserved) and re-tags its vNIC into the quarantine VLAN, OPNsense blocks 10.20.4.15 and RS-01's address, and privacyIDEA locks the compromised account.
- **Step 3.** Snapshot the paused VM's memory and disk, export SIEM/FIM/Suricata logs, hash everything with SHA-256 and store it in a write-once bucket.
- **Step 4.** Choose the clean point before restoring: diff the 09:06 snapshot against 09:03 (new executables, authorized_keys or cron entries, changed canaries). Use 09:06 if the diff is clean, otherwise 09:03 (before attacker access), and clone it read-only into the recovery environment.
- **Step 5.** Copy data from the clean point onto RS-02 (assumption: ≤200 GB over 10 GbE ≈ 3 min) and run PostgreSQL point-in-time recovery to the clean point (≤5 min) unless the DB audit log shows an earlier malicious write.
- **Step 6.** Compare file hashes with the clean-point manifest, scan with YARA/AV, confirm no new executables, authorized_keys or cron entries, run DB consistency checks and confirm the canary files are intact.
- **Step 7.** Promote RS-02: re-tag its vNIC from the recovery VLAN into the research VLAN, switch the service VIP/DNS, rotate credentials and keep heightened monitoring; only after the evidence is preserved and integrity is verified.

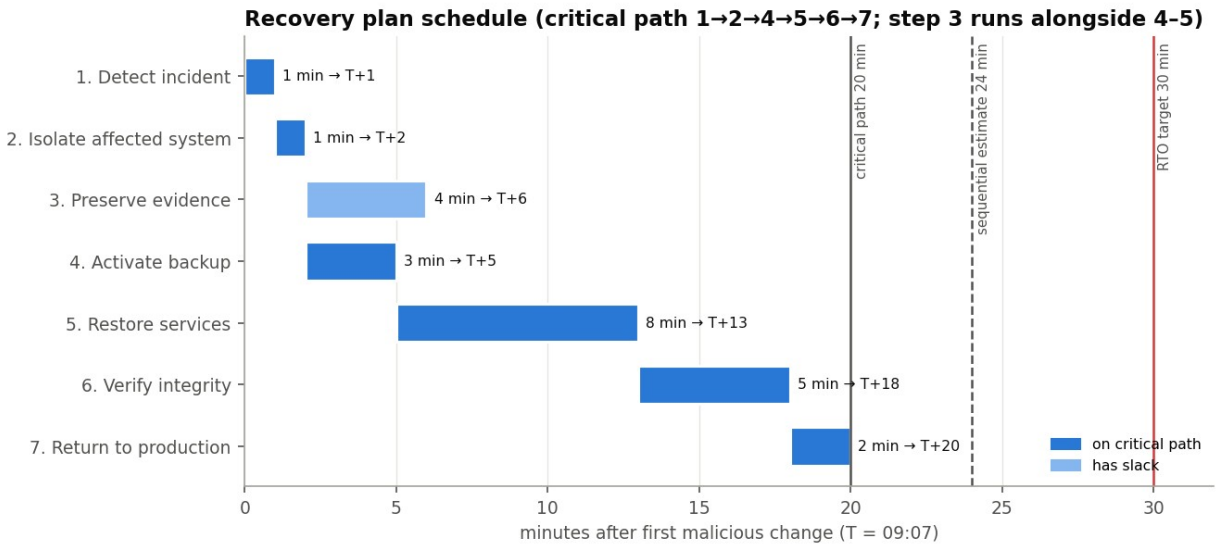


Figure 2. Recovery schedule against the 30-minute RTO.

Part E — AI-Assisted Detection

In plain words: An AI model scored each signal from 0 to 1. All 5 scored at or above the 0.75 cut-off, so all are anomalies (100%). File modifications scored highest and are the most urgent, because they show the encryption itself. AI helps to spot and rank problems, but it cannot block an attacker or restore data, so it supports the fixed security rules rather than replacing them.

Event	Normal score	Observed score	Delta	Anomaly (score ≥ 0.75)
Login failures	0.10	0.81	0.71	yes
File modifications	0.12	0.96	0.84	yes
CPU usage	0.20	0.88	0.68	yes
Outbound traffic	0.15	0.79	0.64	yes
Database requests	0.18	0.91	0.73	yes

1. Calculate the number and rate of detected anomalies. 5 of 5 signals score at or above 0.75, so 5 anomalies are detected and the detection rate is 5/5 = 100%.

2. Identify the highest-priority event. File modifications: observed 0.96 against a normal 0.12 (Δ 0.84, the rise above normal). It has the highest score and the biggest rise, and it marks the start of the encryption at 09:07, so it is the signal that should trigger isolation.

3. Explain why AI-assisted detection should complement, not replace, deterministic security and recovery controls. AI scores are estimates and can be wrong both ways: they raise false alarms and they miss real attacks. Outbound traffic is only 0.04 above the cut-off, so a cut-off of 0.80 would miss the data-theft channel. Research servers often run at 95% CPU during normal calculations, so CPU alone says little. The model only raises an alert: it cannot stop the backup deletion or bring data back. The attacker switched off the antivirus at 09:18, and an AI agent on the same server could be switched off the same way. Normal behaviour also shifts over the semester and exam periods. Fixed rules (MFA, locked backups, blocked outgoing connections) keep working when detection fails and are easy to audit, so AI should sit on top of them to sort and link alerts.

4. Recommend one additional resilience mechanism appropriate for a Kazakhstan university research environment. An offline copy of the backup vault at a second site in Kazakhstan (Almaty, about 970 km from Astana), updated in a daily transfer window and checked by a monthly test restore (see section 6).

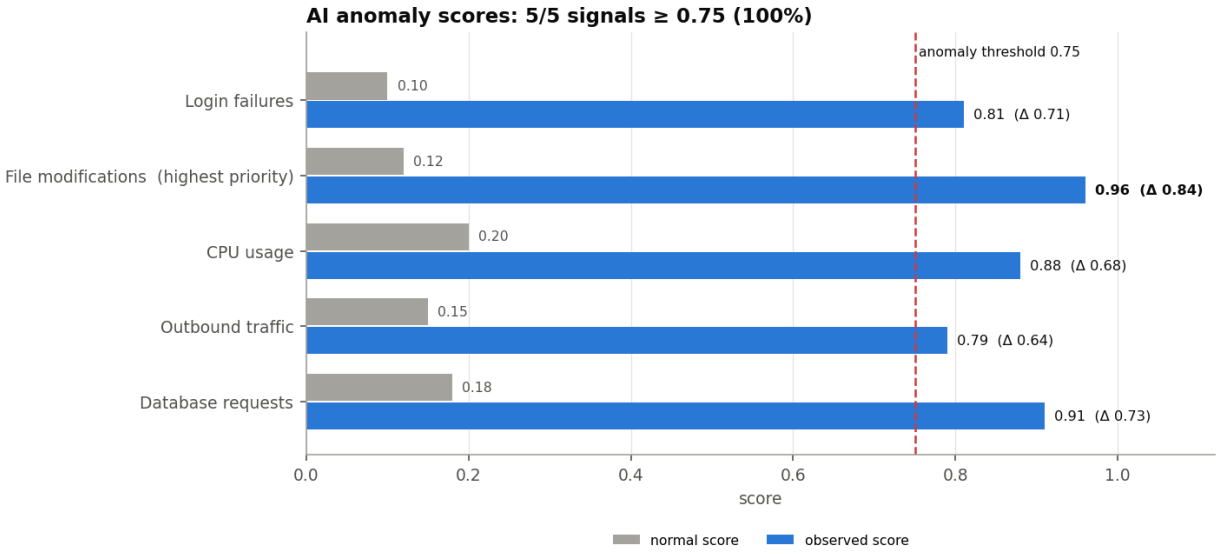


Figure 3. Normal vs observed AI anomaly scores with the 0.75 threshold.

Threshold sensitivity: number of signals flagged at each threshold.

Threshold	Signals flagged
0.75	5
0.80	4
0.85	3
0.90	2
0.95	1

Before/After Simulation

In plain words: The same ten events were replayed against the current setup and against the new design. Without protection, 1,200 files are lost together with the backups. With the new design, the attack is stopped at the first warning. Even if the attacker gets past the login protection, automatic isolation limits the damage to 320 files and the backups survive.

The same ten events are replayed against the as-is system and against the proposed architecture (src/fault4/simulation.py, configs/scenarios.json). Assumptions:

- The replay follows the log exactly; the attacker does not change tactics.
- Each log row covers one minute, so 320 files modified at 09:07 means 320 changes per minute. These changes are assumed to look like encryption (new file endings, random-looking content), so the file-change alarm fires. Its level of 100 changes per minute is a starting value to be tuned on at least one week of real data.
- The 320 modified files are among the 1,200 encrypted ones (the damage is the larger number, not the sum).
- Without protection, the attempt to delete the ordinary (unlocked) backups succeeds.
- The two assume-breach setups switch off all login protection (lockout, MFA bypassed with a stolen session, nobody acting on the 09:01 alert) to test whether detection and locked backups alone still limit the damage. Part D assumes isolation by T+2; manual isolation at T+4 delays the whole recovery by 2 minutes.
- In the protected setup, an attacker guessing slowly (9 or fewer tries per 5 minutes) would avoid the lockout; MFA, not lockout, is what reliably stops the 09:04 login.

Metric	Baseline (as-is)	Hardened	Assume breach, automated isolation	Assume breach, manual isolation
Attacker gains a session	yes	no	yes	yes
Attack stopped / contained at	never	09:01	09:09	09:11
First automated detection	none	09:01	09:01	09:01
Files impacted	1,200	0	320	1,200
Backups destroyed	yes	no	no	no
Exfiltration channel open	yes	no	no	no
Antivirus disabled	yes	no	no	no
Data loss, min	unbounded (backups lost)	none	1 (fallback 4)	1 (fallback 4)
Recovery time, min	not achievable	no recovery needed	24	26

With automatic isolation the damage drops from 1,200 to 320 files (73.3% fewer). With manual isolation all 1,200 files are hit, but the data still comes back within the RPO and RTO targets because the backups could not be deleted. Automation limits how much is damaged; locked backups make sure it can always be restored.

Conclusion

The attacker went from the first login attempt to switching off the antivirus in 17 minutes, with nothing reacting automatically: 1,200 files were encrypted and the backups were attacked. The proposed design answers each stage of the attack with a control that prevents it, one that detects it and one that recovers from it. In the replay, the login lockout stops the attack at 09:01, and MFA would also reject the 09:04 login. If the login protection is bypassed, automatic isolation at 09:09 limits the damage to 320 files (73.3% fewer), the locked backups survive the 09:12 deletion attempt and blocked outgoing connections stop the 09:13 channel. The estimated recovery time is 24 min (20 min on the critical path) against a 30-minute RTO target, with a worst-case data loss of 4 min against a 5-minute RPO target. AI scoring flags all signals (100%) and ranks file modifications first, but outbound traffic is only 0.04 above the cut-off, which shows why AI must support, not replace, fixed security rules.

STUDENT TECHNICAL WORK REPORT / SUBMISSION RECORD

Assignment 4 — Security, Resilience, and Intrusion Tolerance

Purpose: This form is a formal submission record. The student must complete every applicable field and attach evidence of their own work. Short generic explanations are not sufficient.

1. Student and Submission Information

Required field	Student entry
Student full name	Talgatov Aibyn
Student ID	255308
Group / cohort	CSE-2505M
Instructor	Serek Azamat
Date of submission	____ / ____ / _____
Individual variant / task code assigned by instructor	_____
Git repository / project link	https://github.com/a169n/fault_4
Attached code / file names	src/fault4/*.py, tests/*.py, data/*.csv, configs/scenarios.json, outputs/results.json, outputs/run_log.txt, outputs/test_log.txt, outputs/figures/*.png, run_all.sh

2. Work Period and Task Record

Item	Student entry
Work start date/time	2026-10-31 10:43 (UTC+5, Astana)
Work completion date/time	2026-11-06 15:07 (UTC+5, Astana)
Main task completed	Assignment 4 Parts A–E (incident classification, risk matrix, resilient architecture, recovery plan, AI anomaly analysis) plus a before/after attack simulation
Tools / technologies used	Python 3.9+, matplotlib 3.9.4, python-docx 1.1.2, pytest 8.3.5, Git/GitHub, LibreOffice (PDF export), macOS
Main technical output produced	Reproducible analysis pipeline (python -m fault4 all), results.json, 4 figures, 4-scenario simulation, this report

3. Report Structure to Complete

For each section below, write the requested evidence in your own words. Include calculations, diagrams, code references, screenshots, logs, or experimental evidence where applicable.

1. Incident Analysis

Classify every incident event into an attack stage, provide evidence from the synthetic dataset, and assess risk.

Required content	Student response / evidence
Summary	All 10 events are classified. The attacker first tested the login (09:01), then guessed passwords (36 failed attempts in total) and got in at 09:04. Three minutes later files began to change, and by 09:10 1,200 files were encrypted. The attacker then tried to delete the backups (09:12), opened a connection to an unknown outside address (09:13), read heavily from the database (09:15) and switched off the antivirus (09:18). The whole attack took 17 minutes and nothing stopped it automatically: the antivirus was running during the encryption and did not react.
Evidence / calculation / artifact reference	Part A table; code src/fault4/incident.py; outputs/results.json → incident. Measured from the log: 36 failed logins, access gained after 3 min, encryption started 6 min after access, 17 min in total. Each row quotes the log and names the matching MITRE ATT&CK technique.

Required content	Student response / evidence
Student-specific decision or observation	Four events can be read in more than one way (09:01, 09:08, 09:15, 09:18); the Part A table gives the other reading for each. I treat the database spike at 09:15 as lateral movement: the attacker used the captured server as a stepping stone to the research database, which I assume runs on a separate machine. I raised the 09:04 login from High to Critical because everything that followed depended on it.

2. Risk Matrix

Assign likelihood and impact, calculate Risk = Likelihood × Impact, and justify the resulting priority.

Required content	Student response / evidence
Summary	Ransomware ranks first (5 × 5 = 25). Backup destruction and credential compromise follow with 20 each (Critical). Data exfiltration and privilege escalation score 16 (High). When two threats have the same score, the one with the larger impact ranks higher.
Evidence / calculation / artifact reference	Ransomware 5 × 5 = 25 (Critical); Backup destruction 4 × 5 = 20 (Critical); Credential compromise 5 × 4 = 20 (Critical); Data exfiltration 4 × 4 = 16 (High); Privilege escalation 4 × 4 = 16 (High). Code src/fault4/risk.py; Figure 4. I also checked how stable each priority is by moving the likelihood one step down or up: only ransomware stays Critical one step down, and data exfiltration and privilege escalation become Critical one step up.
Student-specific decision or observation	One simple rule for every likelihood: 5 if the log shows the threat happened and worked, 4 if it shows only an attempt or an indirect sign. The order of fixing things is a separate choice from the risk rank: MFA comes first because it removes the cause (a guessed password was enough to get in), and immutable backup second because it still saves the data when every other layer fails.

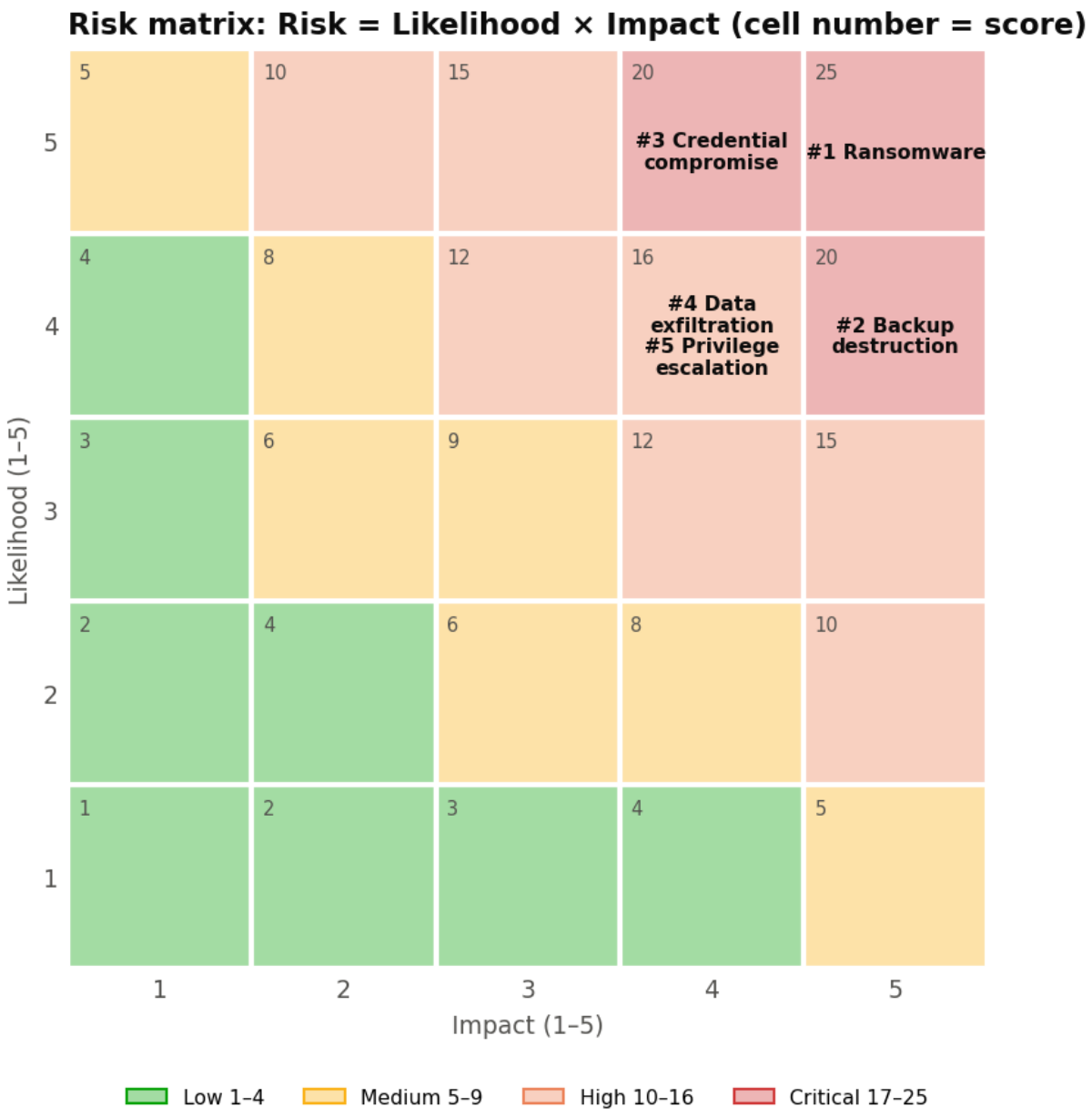


Figure 4. Risk matrix (Risk = Likelihood × Impact).

3. Resilient Security Architecture

Design the required architecture containing MFA, segmentation, immutable backup, monitoring, intrusion detection, secure failover, and recovery environment.

Required content	Student response / evidence
Summary	The research server sits behind a firewall that splits the network into separate zones: access, research, data, security, backup and recovery. All seven required parts are included: MFA, network segmentation, immutable backup, monitoring, intrusion detection, secure failover to a spare server (RS-02) and an isolated recovery environment. An offline copy in Almaty is added as an extra.

Required content	Student response / evidence
Evidence / calculation / artifact reference	Part C table and component list; Figure 1 with the numbered control flow (1)–(7); src/fault4/controls.py. An automatic check in the code confirms that every required part exists, every threat has a preventive, a detective and a recovery control, and no part is left unused.
Student-specific decision or observation	The spare server is filled from a backup, not kept as a live copy: a live copy would have received the 1,200 encrypted files as well. RS-02 waits in a separate network the attacker cannot reach and joins the research network only after its data has been checked. The infected server is cut off by the hypervisor, which moves it into a quarantine network; the table marks this “Respond:” in the recovery column.

4. Recovery Plan

Complete the seven-step recovery plan and show how your target RPO ≤ 5 minutes and RTO ≤ 30 minutes are addressed.

Required content	Student response / evidence
Summary	Seven steps, timed from the first harmful change at 09:07 (T): 1+1+4+3+8+5+2 = 24 min if done one after another, and 20 min when evidence collection runs at the same time as steps 4–5. Both estimated recovery times are within the 30-minute RTO target. The worst-case data loss is 3 + 1 = 4 min, within the 5-minute RPO target.
Evidence / calculation / artifact reference	Part D table; src/fault4/recovery.py; Figure 2. Backups are taken every 3 min starting at 09:00 and reach the vault 1 min later. Two clean restore points: 09:06 (the last backup before 09:07) loses 1 min of work; 09:03 (before the attacker logged in at 09:04) loses 4 min.
Student-specific decision or observation	I chose a 3-minute backup interval because a 5-minute interval plus the 1-minute delay would lose 6 minutes and miss the target. The restore point is chosen before restoring: the attacker was inside from 09:04 and may have left a back door, so 09:06 is used only if it shows no unexpected changes compared with 09:03. Choosing first keeps either option inside the RTO.

5. AI-Assisted Detection

Calculate the anomaly count/rate, identify the highest-priority event, and explain the role and limitations of AI-assisted detection.

Required content	Student response / evidence
Summary	All signals are at or above 0.75: 5/5 = 100%. File modifications is the highest-priority event (0.96, Δ 0.84) and matches the moment data started being destroyed. AI scoring helps to find and rank problems, but it cannot replace fixed security rules.
Evidence / calculation / artifact reference	Rise above normal (Δ): Login failures 0.71, File modifications 0.84, CPU usage 0.68, Outbound traffic 0.64, Database requests 0.73. With cut-offs of 0.75/0.80/0.85/0.90/0.95 the number of anomalies is 5/4/3/2/1. Code src/fault4/anomaly.py; Figure 3.
Student-specific decision or observation	I rank by how far each signal rose above normal and by where it sits in the attack, not by the ratio to normal. The ratio would put login failures first (8.10× vs 8.00×) only because its normal value is very small. I keep the cut-off at 0.75: at 0.80, outbound traffic (0.79, only 0.04 above the cut-off), the sign of data theft, would be missed.

6. Additional Resilience Recommendation

Recommend one additional resilience mechanism appropriate for the synthetic Kazakhstan university research environment and justify it.

Required content	Student response / evidence
Summary	Recommended: an offline copy of the backups at a second site in Kazakhstan (Almaty). It is updated once a day in a short transfer window opened from the Almaty side, moved to disconnected media every month and test-restored every month.
Evidence / calculation / artifact reference	Both backup tiers in Astana (tier 1: snapshots, 4 min worst-case data loss; tier 2: locked copies every 15 min) share one site and one set of administrators. The Almaty copy (about 970 km away) is a daily tier that survives a takeover of the backup administrators or the loss of the whole Astana site. Modelled as offline_copy in src/fault4/controls.py and flow (7) in Figure 1.
Student-specific decision or observation	A second site inside Kazakhstan rather than a foreign cloud: Law of the Republic of Kazakhstan No. 94-V “On Personal Data and Their Protection”, Article 12, requires databases with personal data to be kept on the territory of Kazakhstan, and research data may include personal data of study participants.

4. Individual Work and Anti-Plagiarism Record

Because the assignment uses a common educational scenario and dataset, the submitted report must contain verifiable evidence of the individual student's work. Copying another student's wording, calculations, architecture, code, logs, screenshots, or conclusions is not acceptable.

- Use your own threat/control mapping rather than copying another student's table wording.
- Tie each risk score to your own justification.
- Provide a unique architecture diagram and explain its control flow.
- Record the exact source file/version used for your analysis.
- Be prepared to defend why one control is preventive, detective, or recovery-oriented.

Individual evidence	Student entry
My unique technical decision	Backups every 3 min, chosen after counting the 1-minute delay (3 + 1 = 4 ≤ 5, while 5 + 1 = 6 would miss the RPO target); a rule with two clean restore points, decided before restoring (09:06 if it shows no unexpected changes compared with 09:03, otherwise 09:03, before the attacker logged in); and a spare server kept in a separate network instead of a live copy.
My own implementation / calculation evidence	A Python package (fault4) with automated tests (outputs/test_log.txt) and a replay of the attack in four setups. Without protection, 1,200 files and the backups are lost. With the new design the attack stops at 09:01. With the login protection bypassed, automatic isolation limits the damage to 320 files (73.3% fewer). With manual isolation all 1,200 files are hit but still recovered, 2 min later. Estimated recovery time 24 min (critical path 20 min), worst-case data loss 4 min.
Exact file, code, commit, notebook, or log reference	https://github.com/a169n/fault_4: code at commit 1a2c5c1-dirty (outputs and this report are committed in the next commit on main); fault4 v1.0.0. Dataset transcribed from Assignment_4_AITU_Security_Resilience_Report_Template.pdf (SHA-256 a1c8c43e799a9f2f…): incident table p.1, Part E table p.2, into data/incident_events.csv (SHA-256 b4b3b59765035a9f…) and data/anomaly_scores.csv (SHA-256 d50d601682cda1f6…). Outputs: outputs/results.json, outputs/run_log.txt.
One problem I personally encountered and how I solved it	Two ways of ranking the anomalies gave different winners: login failures by ratio (8.10×) and file modifications by rise above normal (Δ 0.84). I chose the rise plus the attack stage, because a ratio makes signals with a tiny normal value look bigger than they are, and I show both in Part E.
One limitation of my own solution	Only one synthetic attack, replayed with an attacker who does not adapt. The file-change alarm level (100 changes per minute) was set knowing this attack, so it may fit it too closely. False alarms were not measured. Recovery step times are estimates, not timed drills. The 4-minute worst-case data loss holds for the preferred restore point; with the fallback point, the loss grows with how long the attacker was inside before doing damage (here 3 min).

5. Evidence Checklist

☒ **Completed required tables and calculations** — Parts A–E tables; outputs/results.json

☒ **Architecture / RBD / FTA / security diagram where applicable** — outputs/figures/architecture.png (Figure 1)

☒ **Source code or configuration files where applicable** — src/fault4/*.py, configs/scenarios.json

☒ **Execution logs / experiment results where applicable** — outputs/run_log.txt, outputs/test_log.txt

☒ **Screenshots or other reproducible evidence where applicable** — ./run_all.sh reproduces outputs/results.json byte-identically (SHA-256 values in the Appendix); outputs/figures/*.png

☒ **Links to code, datasets, notebooks, or artifacts** — https://github.com/a169n/fault_4; data/*.csv

☒ **Before/after comparison where applicable** — Before/after simulation section (4 scenarios)

☒ **Final technical conclusion** — Conclusion section

6. Student Declaration

I confirm that this report describes my own work. I have not copied another student's report, code, calculations, diagrams, logs, screenshots, or conclusions. Any external source or reused material has been identified. I understand that I may be asked to reproduce or explain any part of this submission during the oral defense.

Role	Name	Signature	Date
Student / Executor	Talgatov Aibyn	_____	_____
Instructor / Accepted by	Serek Azamat	_____	_____

7. Instructor Acceptance Record

Check	Status / comment
Report structure completed	☐ Yes ☐ No Comment: _____
Evidence is sufficient	☐ Yes ☐ No Comment: _____
Individual contribution is identifiable	☐ Yes ☐ No Comment: _____
Oral defense completed	☐ Yes ☐ No Comment: _____
Final status	☐ Accepted ☐ Revision required

References and external sources

1. MITRE ATT&CK Enterprise matrix, https://attack.mitre.org — techniques and tactics T1589, T1110.001, T1078, T1486, T1490, T1041, T1213, T1562.001, TA0008 (accessed 31 October 2026).
2. Law of the Republic of Kazakhstan No. 94-V of 21 May 2013 “On Personal Data and Their Protection”, Article 12, https://adilet.zan.kz/eng/docs/Z1300000094 (accessed 31 October 2026).
3. NIST SP 800-61 Rev. 3 (April 2025), Incident Response Recommendations and Considerations for Cybersecurity Risk Management, https://doi.org/10.6028/NIST.SP.800-61r3 (basis for separating Respond from Recover).
4. Vendor documentation: privacyIDEA, OPNsense, Wazuh, Suricata, MinIO Object Lock, OpenZFS send/receive, PostgreSQL continuous archiving and point-in-time recovery, fapolicyd.
5. Assignment specification: Assignment_4_AITU_Security_Resilience_Report_Template.pdf (SHA-256 a1c8c43e799a9f2f31d9b5200f772ab99b37054ad648dbaa6d4770475675e35a).

6. AI assistance: analysis code and draft text were prepared with the help of an AI coding assistant (Claude, Anthropic); the student reviewed, ran and verified all results.

Appendix — Reproducibility

fault4 v1.0.0, commit 1a2c5c1-dirty. Commands:

- python3 -m venv .venv
- .venv/bin/pip install -r requirements.txt
- ./run_all.sh # tests, analysis, figures, report, PDF
- PYTHONPATH=src .venv/bin/python -m fault4 analyze # results.json and run_log.txt only

File	SHA-256
Assignment_4_AITU_Security_Resilience_Report_Template.pdf	a1c8c43e799a9f2f31d9b5200f772ab99b37054ad648dbaa6d4770475675e35a
anomaly_scores.csv	d50d601682cda1f6bd3ef5381520f215989eea1b3f14402f44bb85f42d272a0d
incident_events.csv	b4b3b59765035a9fd853bc643ded10d73fa8a3284bb49c4e34ccad0842d2ed91
scenarios.json	65637ad3a1ba280d3316c94c054c59a757c1a5dd610aba59947064ceeefacd30